

TUGAS PRAKTIKUM 7

Nama : Muhammad 'Azmi Salam

NIM : 2406010

Kelas : C2

1. Analisis Risiko Web Pembayaran Dummy

1.1 Threat Model

Aset	Klasifikasi	Threat Actor	Threat	Dampak Potensial
Data Pembayaran	Confidential	External Attacker	SQL Injection pada endpoint transaksi	Kebocoran data finansial nasabah secara massal
Password User	Private	External Attacker	Password terekspos di API response	Hash dapat di-crack menggunakan lookup table
Session Token	Private	External Attacker	JWT algorithm manipulation	Privilege escalation ke role admin
Data Transaksi	Private	External Attacker	IDOR pada endpoint transaksi	Akses tidak sah ke data transaksi pengguna lain
Kredensial Login	Private	External Attacker	Brute force pada endpoint login	Akun pengguna dapat diambil alih
Data Profil Pengguna	Private	Internal Attacker	Stored XSS pada form profil	Eksekusi script berbahaya di browser pengguna lain

1.2 Analisis Kuantitatif

Threat	AV (Rp)	EF	SLE (Rp)	ARO	ALE (Rp)
SQL Injection	800.000.000	60%	480.000.000	1	480.000.000
Exposed Hash	200.000.000	40%	80.000.000	2	160.000.000
JWT Manipulation	500.000.000	70%	350.000.000	0,5	175.000.000
IDOR	300.000.000	30%	90.000.000	1	90.000.000
Brute Force	150.000.000	50%	75.000.000	3	225.000.000
Stored XSS	250.000.000	35%	87.500.000	0,5	43.750.000

Justifikasi Nilai

Threat	Justifikasi AV	Justifikasi EF	Justifikasi ARO
--------	----------------	----------------	-----------------

SQL Injection	Database finansial nasabah + sanksi regulasi	60% — satu serangan ekspos mayoritas data	1 — serangan SQLi masih umum pada web finansial
Exposed Hash	Database kredensial pengguna	40% — hanya hash, perlu di-crack	2 — human error serialisasi API cukup sering
JWT Manipulation	Akses administratif sistem	70% — privilege escalation = kendali penuh	0,5 — butuh pengetahuan teknis JWT
IDOR	Data transaksi pengguna	30% — terbatas pada endpoint spesifik	1 — mudah ditemukan dengan enumerasi
Brute Force	Rata-rata nilai akun pengguna	50% — tergantung kekuatan password	3 — automated tools mudah dijalankan
Stored XSS	Data profil & cookie session	35% — terbatas pengguna buka halaman profil	0,5 — butuh entry point lolos validasi

1.3 Risk Matrix (Kualitatif)

Threat	Likelihood	Impact	Risk Level
SQL Injection	High	Critical	Critical
Exposed Hash	High	Medium	High
JWT Manipulation	Medium	High	High
IDOR	Medium	High	High
Brute Force	High	Medium	High
Stored XSS	Low	High	Medium

1.4 Risk Treatment Plan

Threat	Risk Level	Label	Strategi/Alasan
SQL Injection	Critical	M	Parameterized query / prepared statement + WAF. Biaya ~Rp15jt, ALE Rp480jt => ROI jelas.
Exposed Hash	High	M	DTO/serializer eksplisit, field sensitif tidak pernah di response. Biaya minimal.
JWT Manipulation	High	M	Whitelist algoritma JWT, library terpercaya, verifikasi signature tiap request. Biaya rendah.
IDOR	High	M	Ownership check tiap endpoint, UUID instead of incremental ID. Biaya rendah.
Brute Force	High	M	Rate limiting, account lockout 5x gagal,

			CAPTCHA. Biaya sangat rendah.
Stored XSS	Medium	M	Output encoding, CSP headers, sanitasi input HTML. Biaya rendah.

Keterangan Label: *M* = Mitigation | *A* = Accept | *T* = Transfer | *Av* = Avoid

2. Risk Management Report — Karlan Trading Company

2.1 Deskripsi Sistem

Kjerag Logistics & Trading Management System (KLTMS) adalah sistem informasi terpadu milik Karlan Trading Company untuk mengelola operasi logistik dan perdagangan di wilayah pegunungan Kjerag. Sistem menghubungkan kantor pusat, gudang penyimpanan, mitra bisnis, dan tim logistik lapangan. KLTMS menangani manajemen inventaris gudang berbasis IoT, pelacakan pengiriman real-time, kontrak dagang dengan mitra, serta pelaporan keuangan dan audit — semuanya dalam satu platform terintegrasi dengan arsitektur yang resilient terhadap keterbatasan infrastruktur jaringan Kjerag.

2.2 Komponen Sistem

- Frontend Web App — Portal akses berbasis browser (React.js)
- Backend API Server — RESTful API (Node.js/Express)
- Database Server — Penyimpanan data utama (PostgreSQL)
- Warehouse IoT Gateway — Perangkat IoT gudang (barcode scanner, sensor stok)

2.3 Tipe Pengguna

- Admin Sistem — Manajemen user, konfigurasi, audit log
- Staff Logistik — Manajemen inventaris, pemrosesan pengiriman
- Client/Mitra Bisnis — Lacak kiriman, akses kontrak, buat permintaan
- Auditor — Akses read-only untuk kepatuhan & review

2.4 Data Asset & Klasifikasi

Data Asset	Klasifikasi	Deskripsi
Kontrak Dagang & Harga	Confidential	Perjanjian bisnis, harga khusus mitra, strategi dagang
Data Personal Karyawan	Private	Gaji, alamat, dokumen identitas
Data Pelacakan Pengiriman	Public	Status & lokasi pengiriman, estimasi waktu tiba
Laporan Keuangan Internal	Restricted	P&L, revenue, metrik finansial internal

Data Inventaris Gudang

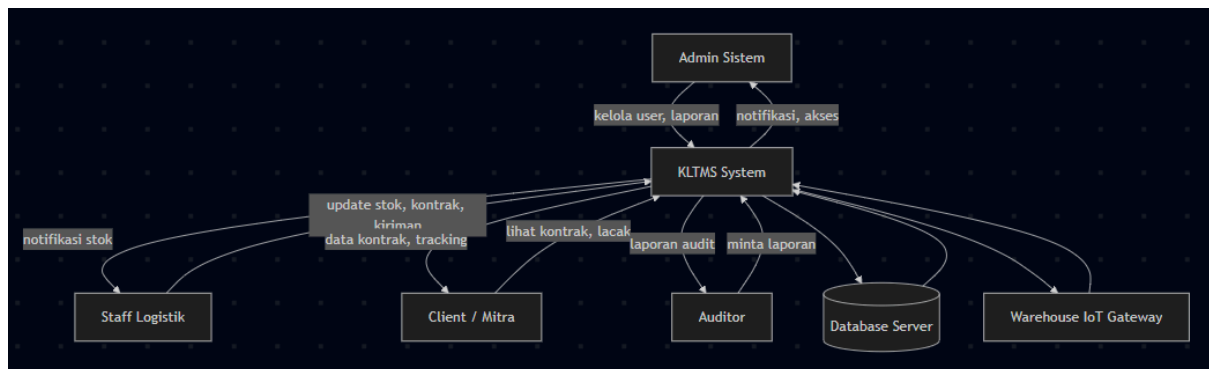
Internal

Stok barang, kapasitas gudang,
riwayat masuk/keluar

2.5 DFD Level 0 (Context Diagram)

- External Entities: Admin Sistem, Staff Logistik, Client/Mitra, Auditor
- Main Process: KLTMS System
- Data Stores: Database Server, Warehouse IoT Gateway

Data Flows:



2.6 DFD Level 1

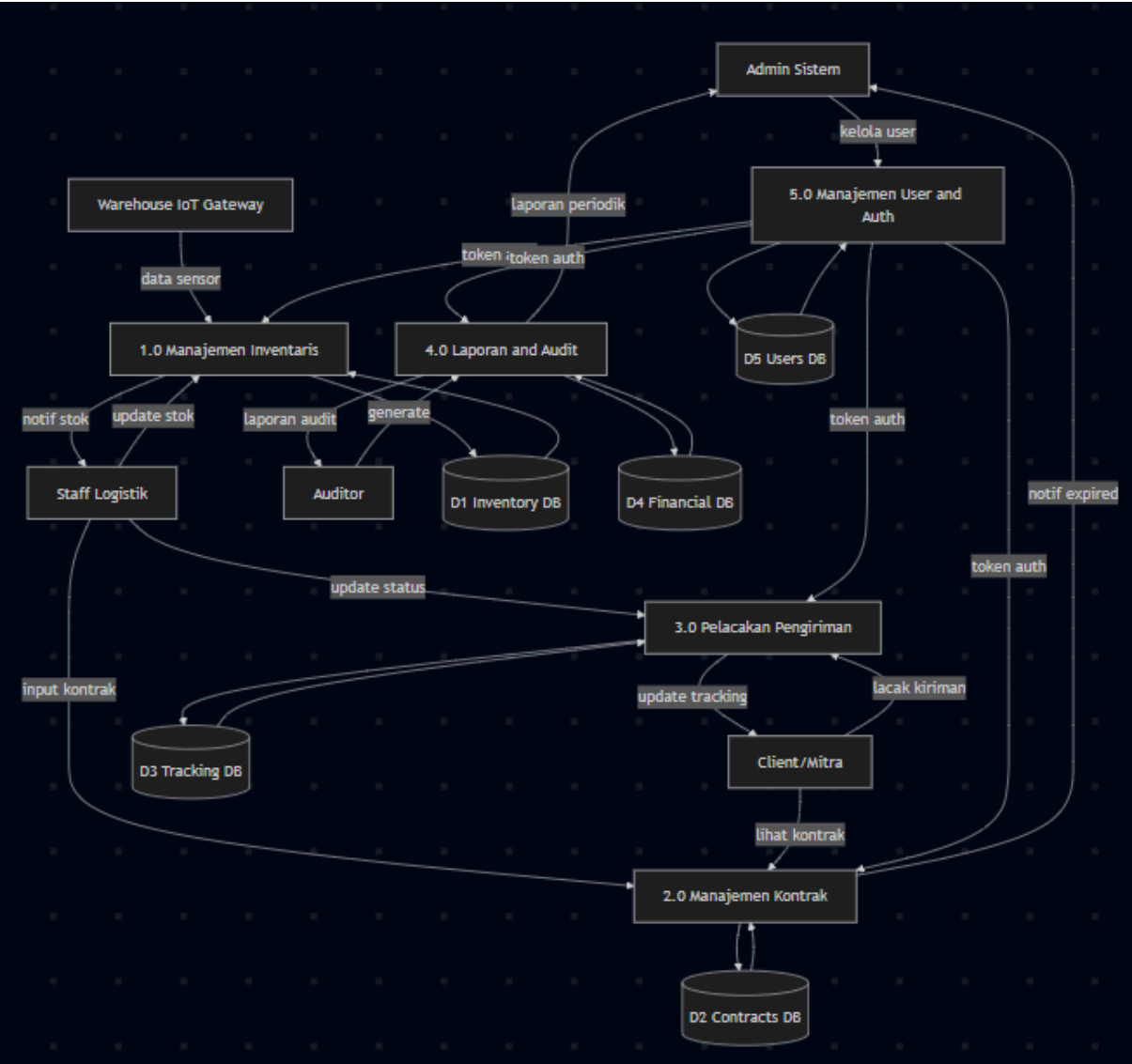
Proses dalam KLTMS:

- 1.0 Manajemen Inventaris — Mengelola stok gudang, input dari Staff & IoT Gateway
- 2.0 Manajemen Kontrak Dagang — Mengelola kontrak mitra
- 3.0 Pelacakan Pengiriman — Update & lacak status kiriman
- 4.0 Laporan & Audit — Generate laporan keuangan & audit
- 5.0 Manajemen User & Auth — Kelola user, role, otentikasi & otorisasi

Data Stores:

- D1 Inventory DB | D2 Contracts DB | D3 Tracking DB
D4 Financial DB | D5 Users DB

Data Flows:



2.7 Threat Model

Aset		Klasifikasi	Threat Actor	Threat	Dampak Potensial
Kontrak Dagang & Harga	pd	Confidential	External Attacker	SQL Injection endpoint kontrak	Kebocoran data harga & strategi ke kompetitor
Data Karyawan	Personal	Private	Malicious Insider	Privilege escalation Staff -> data HR	Eksposur data pribadi seluruh karyawan
Data Pelacakan		Public	External Attacker	MITM komunikasi Gateway	Pemalsuan data lokasi & status kiriman
Session Admin	Token	Restricted	External Attacker	XSS pada portal admin	Pengambilalihan sesi admin = akses penuh
Data Gudang	Inventaris	Internal	Competitor	API scraping endpoint inventaris	Analisis kompetitor stok & kapasitas

Laporan Keuangan	Restricted	External Attacker	SSRF pd fitur export laporan	Eksfiltrasi data keuangan internal
Semua Transaksi	Data Confidential	External Attacker	Weak JWT secret -> token forgery	Token palsu untuk akses tak sah

2.8 Risk Measurement Kuantitatif

Threat	AV (Rp)	EF	SLE (Rp)	ARO	ALE (Rp)
SQL Injection (Kontrak)	2.500.000.000	70%	1.750.000.000	0,5	875.000.000
Privilege Escalation	1.000.000.000	40%	400.000.000	1	400.000.000
MITM IoT Gateway	750.000.000	25%	187.500.000	2	375.000.000
XSS (Session Admin)	3.000.000.000	80%	2.400.000.000	0,3	720.000.000
API Scraping Inventaris	500.000.000	30%	150.000.000	4	600.000.000
SSRF (Laporan Keuangan)	2.000.000.000	60%	1.200.000.000	0,2	240.000.000
JWT Forgery	1.500.000.000	65%	975.000.000	0,3	292.500.000

Justifikasi Asset Value & ARO

Threat	Justifikasi AV	Justifikasi ARO
SQL Injection (Kontrak)	Kerugian jika kontrak & harga bocor: hilang keunggulan kompetitif + NDA	0,5 — SQLi masih umum tapi ada mitigasi standar
Privilege Escalation	Denda regulasi + kompensasi + reputasi	1 — insider threat umum di organisasi menengah
MITM IoT Gateway	Gangguan operasional akibat kiriman salah di pegunungan	2 — jaringan pegunungan tidak selalu terenkripsi
XSS (Session Admin)	Kerugian maksimal karena akses penuh ke seluruh sistem	0,3 — XSS diketahui, ada CSP
API Scraping	Informasi stok & kapasitas untuk kompetitor	4 — scraping mudah otomatis
SSRF (Keuangan)	Laporan keuangan internal bocor publik	0,2 — butuh konfigurasi spesifik
JWT Forgery	Akses tak sah ke transaksi & kontrak	0,3 — butuh pengetahuan teknis JWT

2.9 Risk Measurement Kualitatif

Threat	Likelihood	Impact	Risk Level
--------	------------	--------	------------

SQL Injection (Kontrak)	Medium	Critical	Critical
Privilege Escalation	High	High	High
MITM IoT Gateway	High	Medium	High
XSS (Session Admin)	Low	Critical	High
API Scraping Inventaris	High	Low	Medium
SSRF (Keuangan)	Low	Critical	High
JWT Forgery	Low	High	Medium

Risk Matrix:

Likelihood \ Impact	Low	Medium	High	Critical
High	API Scraping	MITM IoT	Priv. Escalation	—
Medium	—	—	—	SQL Injection
Low	—	—	JWT Forgery	XSS, SSRF

2.10 Risk Treatment Plan

Threat	Risk Level	Label	Strategi/Alasan
SQL Injection (Kontrak)	Critical	M	Parameterized query/ORM + WAF. Biaya Rp20jt, ALE Rp875jt => ROI jelas.
Privilege Escalation	High	M	RBAC ketat + least privilege. Review mapping tiap kuartal. Biaya Rp10jt.
MITM IoT Gateway	High	M	TLS 1.3 + mTLS utk autentikasi perangkat. Biaya Rp25jt, ALE Rp375jt.
XSS (Session Admin)	High	M	CSP headers, output encoding, HttpOnly+Secure cookies. Biaya rendah.
API Scraping	Medium	T	Transfer risiko ke CDN dgn rate limiting via SLA. Rate limiting tetap di API.
SSRF (Keuangan)	High	M	Whitelist URL, network segmentation, firewall. Biaya Rp5-15jt.
JWT Forgery	Medium	M	JWT secret kuat (256-bit), rotasi berkala, nonaktifkan algoritma lemah.

Keterangan Label Treatment (ISO/IEC 27005):

M = Mitigation — implementasi kontrol keamanan

A = Accept — terima risiko (ALE < biaya treatment, didokumentasikan)

T = Transfer — transfer risiko ke entitas lain (asuransi/CDN/eksternal)

Av = Avoid — hindari dengan tidak mengimplementasikan fitur/sistem